

L2 - 10.3. Response and Recovery

Task 1 - Introduction

The attacker is inside the Nexus Financial environment. The Detection and Analysis phase confirmed the compromise, identified the affected accounts, and mapped the initial attack chain. This room covers Response and Recovery, the phase where the IR team transitions from understanding the incident to actively resolving it. In NIST SP 800-61r2 terms, this maps to the Containment, Eradication, and Recovery phase.

Task 2 - Responding to an Incident

When a security incident is confirmed, the investigation phase is over, and the response phase begins. This is the moment where the IR team stops observing and starts acting. According to NIST SP 800-61r2, the response happens through three tightly coupled activities that must be executed in a specific order.

Activity	Goal	Key Question
Containment	Stop the damage from spreading any further	What do we need to cut off right now?
Eradication	Remove all attacker presence from the environment	Is the attacker completely gone?
Recovery	Restore normal operations safely	Can we bring things back online without risk?

The order is important. You cannot eradicate without first containing. You cannot recover without first eradicating. Rushing any one of them undermines the others and risks giving the attacker a path back in.

A common mistake IR teams make is moving to eradication before containment is complete, or recovering systems before the attacker has been fully removed. Both lead to the same outcome: the attacker regains access, and the team is back to square one. This cycle of repeatedly finding and removing the same threat across

the environment is sometimes called the whack-a-mole problem, and it almost always stems from skipping steps or moving too fast.

Environment Matters

How these three activities are executed depends heavily on the environment in which they are performed. An incident in an on-premises Active Directory environment requires different actions than one in a cloud-based environment. An endpoint compromise requires different responses than a cloud identity compromise.

This is where playbooks become valuable. A playbook is a pre-defined, step-by-step response guide tailored to a specific incident type and environment. Rather than figuring out the right containment and eradication actions from scratch during a live incident, the IR team follows a playbook built for exactly this scenario. A well-maintained playbook library means responses are faster, more consistent, and less dependent on any single analyst's knowledge.

This module follows a Microsoft 365 incident. The attacker gained access via compromised cloud credentials and operated entirely within Microsoft 365. This means the response actions in this room are specific to the Microsoft 365 environment. In a different environment, the same three activities would apply, but the specific actions would look very different.



Answer the questions below

According to NIST SP 800-61r2, what is the first activity that must happen before eradication can begin?

Containment

Task 3 - Stopping the Damage

When an attacker is active inside an environment, every minute they remain uncontained is a minute they can use to access more data, compromise more

accounts, or establish further persistence. The immediate priority is to stop the damage from spreading. In incident response, this is called containment.

Containment does not mean the attacker is gone. It means their ability to cause further harm has been limited while the IR team works on removing them completely. Think of it as closing the doors before the fire spreads to other rooms. The fire is still there, but it is no longer growing.

Containment Strategies

There are two main approaches to containment, and choosing between them depends on how much the IR team knows about the attacker and how much risk the organization can tolerate.

Full isolation is the most aggressive approach. Affected accounts are disabled, active sessions are terminated, and the attacker's access is completely cut off. This is fast and effective, but has a downside. A sophisticated attacker who suddenly loses access knows they have been discovered. They may have already established persistence elsewhere, and now they know to use it before the IR team finds it.

Controlled isolation is a less aggressive approach. Rather than cutting off the attacker immediately, the IR team monitors their activity closely while limiting what they can access. This allows the team to gather more intelligence before acting. The risk is that the attacker continues operating, even in a limited capacity, during this period.

	Full Isolation	Controlled Isolation
Speed	Immediate	Delayed while monitoring
Risk of tipping off the attacker	High	Low
Intelligence gathered	Limited	High
Best used when	The full scope is well understood, and the attacker must be stopped immediately	Scope is still being determined, and more intelligence is needed

Stopping the Damage in a Microsoft 365 Environment

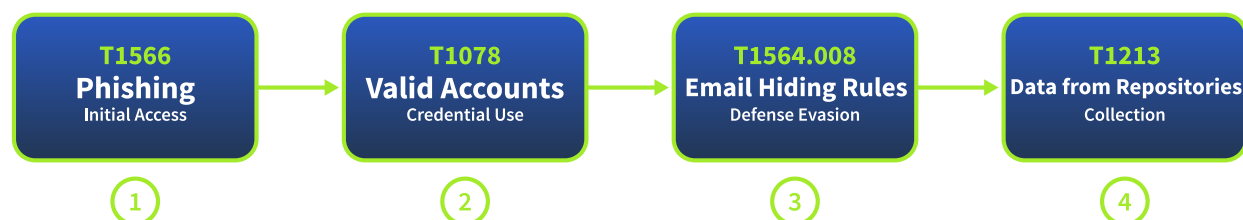
Because this incident occurred entirely within Microsoft 365, stopping the damage does not involve unplugging network cables or isolating physical machines. There are no on-premises systems to segment. Instead, containment is performed through identity and access controls within the Microsoft 365 and Entra ID platform. When a cloud identity is compromised, the attacker's access exists through an authenticated session. Cutting off that access means acting on the identity itself.

MITRE ATT&CK and Containment Decisions

MITRE ATT&CK is a framework that documents the tactics, techniques, and procedures used by real threat actors. Mapping an attacker's actions to MITRE ATT&CK techniques helps the IR team understand what the attacker is trying to achieve and anticipate what they might do next. This directly informs which containment actions to prioritize. In the practical tasks, you will be identifying which of these actions applies to each artifact you find in the logs.

Technique ID	Technique Name	What the Attacker Did	Containment Response
T1566	Phishing	Sent phishing emails to steal credentials	Block phishing domain at the email gateway
T1078	Valid Accounts	Used stolen credentials to sign in as legitimate users	Disable accounts, revoke sessions, reset passwords
T1564.008	Email Hiding Rules	Created inbox rules to suppress security alert emails	Remove the malicious inbox rules immediately
T1213	Data from Information Repositories	Accessed SharePoint to download sensitive files	Review and restrict SharePoint permissions

MITRE ATT&CK - PHISHING INCIDENT KILL CHAIN



Answer the questions below

What containment strategy involves monitoring the attacker's activity rather than cutting off their access immediately?

Controlled Isolation

Task 4 - Cleaning Up

Once the damage has been stopped through containment, the work of cleaning up begins. This means two things: making sure the attacker is completely gone from the environment, and making sure the organization is ready to return to normal operations safely. In incident response, these two activities are called eradication and recovery.

Eradication

Eradication is the process of removing every trace of the attacker from the environment. Containment stopped them from causing more damage, but the attacker may still have a foothold. Malicious inbox rules, OAuth app permissions, persistence mechanisms, or additional accounts they accessed all need to be found and removed before the environment can be considered clean.

The most important principle here is: do not start eradication until the full scope is confirmed. Cleaning up a known compromise while missing a secondary one gives the attacker a path back in. This is the whack-a-mole problem introduced in Task 2. Proper scoping during Detection and Analysis directly determines how complete the clean-up can be.

Because this incident is a Microsoft 365 identity compromise, the clean-up focuses on the identity layer rather than endpoints or network infrastructure. In the practical task, you will be identifying which of these eradication steps applies to what you find in the logs:

- Enforcing MFA on all compromised accounts before re-enabling them
- Removing all malicious inbox rules from affected mailboxes
- Reviewing and revoking any OAuth application permissions granted during the compromise
- Confirming that no additional accounts were accessed from the attacker's IP

- Revoking all external sharing links created by the attacker from SharePoint
- Confirming that no forwarding rules or delegates were added to affected mailboxes

Recovery

Recovery is the process of safely returning to normal operations. It is not simply a matter of re-enabling accounts and moving on. Before any affected account is brought back online, the IR team must confirm that eradication is complete and that the controls that failed during the incident have been addressed.

Recovery also means fixing the root causes that allowed the incident to happen in the first place. In a Microsoft 365 identity incident, root causes typically fall into two categories: identity controls that were missing or misconfigured, and email security controls that allowed the initial phishing to succeed. Both must be addressed before recovery can be considered complete.

Recovery actions are planned across three timeframes. In the practical task, you will be asked to place specific recovery actions into the correct timeframe based on what you find in the logs:

Timeframe	Focus	Example Actions
Near term	Immediate actions before accounts can be re-enabled	Enforce MFA, reset passwords, remove malicious rules, and revoke external shares
Mid term	Controls that address the root causes of the incident	Configure SPF, DKIM, and DMARC, implement Conditional Access policies, and review SharePoint permissions
Long term	Improvements to the overall security posture	Expand SIEM detection rule coverage, run phishing simulations, and update IR policy with escalation timelines

Answer the questions below

| What timeframe should the most critical recovery actions fall under?

Near term

Task 5 - Current Incident Context

The Detection and Analysis room confirmed that a targeted phishing attack was carried out against Nexus Financial. Two employee accounts were compromised through credential theft. The attacker signed in from an overseas IP address, created malicious inbox rules on the compromised accounts to suppress security alerts, and used the first compromised account to send internal phishing emails to other employees.

The IR team has been notified. Initial containment steps are being prepared but have not yet been executed. Before any containment action is taken, the team needs a complete picture of what the attacker did inside the environment after gaining access. That is your job in this room.

Below is the initial SIEM alert that Marcus Webb (SOC L1) received and triaged. This initiated the IR investigation.

Alert Details:

- **Alert Name:** Anomalous Sign-in Detected
- **Time:** 2026-03-30 16:41:30
- **Affected Account:** l.chen@nexusfinancial.thm
- **Corporate IP:** 197.32.45.112

Current IOC Tracker

IOC Type	Value	Hint (if starting from this room)
Attacker IP Address	[Found in the <u>Detection and Analysis</u> room]	Search Entra ID sign-in logs for l.chen@nexusfinancial.thm and look for sign-ins from outside the corporate IP 197.32.45.112
Phishing Sender Address	[Found in the <u>Detection and Analysis</u> room]	Search Message Trace for emails delivered to l.chen@nexusfinancial.thm from external senders before the suspicious sign-in
Compromised Account 1	l.chen@nexusfinancial.thm	Confirmed in the SIEM alert above
Compromised Account 2	[Found in the <u>Detection and Analysis</u> room]	Search Entra ID sign-in logs for any other Nexus Financial accounts that

IOC Type	Value	Hint (if starting from this room)
		show sign-in activity from the attacker's IP
Malicious Inbox Rule	[Found in the <u>Detection and Analysis</u> room]	Search Unified Audit Logs for New-InboxRule operations on l.chen@nexusfinancial.thm from the attacker IP

Available Log Sources: Nexus Financial's Microsoft 365 logs are available in Splunk under the index **ir**. The following log sources are available across all practical tasks in this room:

Log Source	Sourcetype	Key Fields
Entra ID Sign-in Logs	azure:aad:signin	userPrincipalName , ipAddress , location.city , location.countryOrRegion , appDisplayName , status.errorCode , riskLevelDuringSignIn
Message Trace	o365:reporting:messagetrace	Received , SenderAddress , RecipientAddress , Subject , Status , FromIP
Unified Audit Logs	o365:management:activity	Operation , UserId , Workload , ClientIP , ObjectId , SourceFileName , Name , SubjectContainsWords , DeleteMessage

Task 6 - Containment Practical

The Detection and Analysis phase confirmed that two accounts are compromised and an attacker has been active inside the Nexus Financial Microsoft 365 environment. Before the IR team executes containment actions, they need to understand exactly what the attacker did after gaining access. Your job is to investigate that post-compromise activity.

Focus on the Unified Audit Logs. This is where post-compromise activity is recorded. Examine the operations performed on both compromised accounts after the attacker signed in. Check for persistence mechanisms on both mailboxes, any

emails sent from the compromised accounts that suggest lateral movement, and any SharePoint activity that indicates data access.

For each artifact you find, refer back to Task 3 to identify the appropriate containment action. The questions below will alternate between what you find in the logs and what should be done about it.

Use the log sources, sourcetypes, and fields listed in Task 5 to build your queries.

```
index=ir sourcetype="azure:aad:signin" ipAddress!="197.32.45.112"
| table _time userPrincipalName, ipAddress, location.city, location.countryOrRegion, appDisplayName, status.errorCode, riskLevelDuringSignIn
```

Answer the questions below

What keywords does the malicious inbox rule on Laura Chen's account filter for?

security;alert;suspicious;password;verify

```
index=ir sourcetype="o365:management:activity" user_id="l.chen@nexusfinancial.thm" Operation="New-InboxRule"
| table _time Operation, UserId, Workload, ClientIP, ObjectId, SourceFileName, Name, SubjectContainsWords, DeleteMessage
```

The screenshot shows a Splunk search interface. At the top, a search bar contains the query: `index=ir sourcetype="o365:management:activity" user_id="l.chen@nexusfinancial.thm" Operation="New-InboxRule"`. Below the search bar, the results are displayed in a table. The table has columns: `ClientIP`, `ObjectId`, `SourceFileName`, `Name`, and `SubjectContainsWords`. The first row of data shows `ClientIP` as `223.123.4.50:13651`, `ObjectId` as `EURPR10A007.PROD.OUTLOOK.COM/Microsoft Exchange Hosted`, `Name` as `Junk Filter`, and `SubjectContainsWords` as `security;alert;suspicious;password;verify`. The `SubjectContainsWords` field is highlighted with a red underline.

ClientIP	ObjectId	SourceFileName	Name	SubjectContainsWords
223.123.4.50:13651	EURPR10A007.PROD.OUTLOOK.COM/Microsoft Exchange Hosted		Junk Filter	security;alert;suspicious;password;verify

What is the value of the DeleteMessage field in the malicious inbox rule on Laura Chen's account?

True

What is the name of the inbox rule created on the second compromised account?

Security Updates

```
index=ir sourcetype="o365:management:activity" user_id="k.patel@nexusfinancial.thm" Operation="New-InboxRule"
| table _time Operation, UserId, Workload, ClientIP, ObjectId, SourceFileName, Name, SubjectContainsWords, DeleteMessage
```

Based on Task 3, what containment action should be taken against these inbox rules?

Remove the malicious inbox rules immediately

How many internal Nexus Financial employees received the internal phishing email?

3

```
index=ir sourcetype="o365:reporting:messagetrace" FromIP="223.123.4.50"
| table _time Received, SenderAddress, RecipientAddress, Subject, Status, FromIP
```

Based on Task 3, what containment action should be taken against the phishing domain?

Block phishing domain at the email gateway

Task 7 - Eradication and Recovery Practical

Containment has stopped the attacker from causing further damage. Now the focus shifts to two things: confirming the full extent of what the attacker accessed and exfiltrated, and identifying the root causes that allowed this incident to happen. Both must be fully understood before the environment can be considered clean and safe to recover.

Search the Unified Audit Logs for file download and sharing activity across both compromised accounts. Then look at the sign-in logs to identify which security controls were missing. The absence of certain controls will be visible in the logs themselves.

For each finding, refer back to Task 4 to identify the appropriate eradication or recovery action. The questions below will alternate between what you find in the logs and what should be done about it.

Use the log sources, sourcetypes, and fields listed in Task 5 to build your queries.

Answer the questions below

How many files were downloaded from SharePoint across both compromised accounts?

5

```
index=ir sourcetype="o365:management:activity"Operation="File
Downloaded"
| table _time Operation, UserId, Workload, ClientIP, ObjectI
d, SourceFileName, Name, SubjectContainsWords, DeleteMessage
```

1index=ir sourcetype="o365:management:activity"Operation="FileDownloaded"

2| table _time Operation, UserId, Workload, ClientIP, ObjectID, SourceFileName, Name, SubjectContainsWords, DeleteMessage

✓ 5 events (before 9/24/26 1:40:34.000 PM)No Event Sampling ▾

Job ▾||▢→📄⬇️🔍Smart Mode

EventsPatterns**Statistics (5)**Visualization

Show: 20 Per Page ▾

✎Format ▾

☒Preview: On

_time ▾	Operation ▾	UserId ▾	Workload ▾	ClientIP ▾	ObjectID ▾
2026-03-30 16:55:24	FileDownloaded	l.chen@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/Finance-department/Shared Documents/Board_Meeting_Notes_July.docx
2026-03-30 16:55:33	FileDownloaded	l.chen@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/Finance-department/Shared Documents/Employee_Salary_Data.xlsx
2026-03-30 16:55:37	FileDownloaded	l.chen@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/Finance-department/Shared Documents/Q3_Financial_Report.xlsx
2026-03-30 17:03:38	FileDownloaded	k.patel@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/HR-department/Shared Documents/Full_Employee_PII_Data.xlsx
2026-03-30 17:03:45	FileDownloaded	k.patel@nexusfinancial.thm	SharePoint	223.123.4.50	https://nexusfinancial.sharepoint.com/sites/HR-department/Shared Documents/Payroll_Q3_2024.xlsx

What is the name of the first file downloaded by the attacker from Laura Chen's account?

Board_Meeting_Notes_July.docx

Based on Task 4, what eradication action should be taken against the external sharing links created by the attacker?

Revoking all external sharing links created by the attacker from SharePoint

What risk level was assigned to the attacker's sign-ins by Microsoft's risk engine?

none

```
index=ir sourcetype="azure:aad:signin" ipAddress!="197.32.45.112"
| table _time userPrincipalName, ipAddress, location.city, location.countryOrRegion, appDisplayName, status.errorCode, riskLevelDuringSignIn
```

What authentication control was absent that allowed the attacker to sign in without additional verification?

mfa

According to the recovery timeframes in Task 4, what timeframe should MFA enforcement fall under?

Near term

Task 8 - Conclusion

In this room, we covered Response and Recovery, the Containment, Eradication, and Recovery phase of the NIST SP 800-61r2 framework. We learned that these three activities must be performed in sequence and that rushing any one of them risks allowing the attacker to return. We explored the two main containment strategies, mapped the attacker's actions to MITRE ATT&CK techniques, and understood what eradication and recovery look like specifically in a Microsoft 365 environment.

In the practical tasks, we investigated the attacker's post-compromise activity across both compromised accounts. We found evidence of post-access actions taken inside the environment, confirmed the extent of data access and exfiltration, and identified the root causes that made this attack possible. Every finding in this room directly informs the containment and eradication actions the IR team would take.